Privacy Policy - Project AI Chatbot Conversations

Pursuant to art. 13 and art. 14 of EU Regulation No. 2016/679 (GDPR), and in general in observance of the principle of transparency, we herewith provide you with information about the processing of your personal data.

This Privacy Policy is designed to inform you:

- How and why your personal data is being processed
- What personal data is being processed
- What your rights are in relation to the processing of your personal data
- How to contact us so you can exercise your rights.

The project activities

This research project investigates privacy disclosure patterns in publicly shared conversations with AI chatbots (ChatGPT, Microsoft Copilot, and Google Gemini). The study aims to characterize the nature, severity, and prevalence of personal information disclosures in these interactions, and to develop automated frameworks for privacy risk assessment in conversational AI systems.

Planned Processing Activities:

- Data Collection Stage: Collection of URLs to publicly accessible conversation traces through search engine queries. No direct interaction with data subjects occurs. The collection methodology deliberately excludes enumeration techniques.
- Pre-processing and Pseudonymization Stage: All collected conversations undergo automated privacy-preserving transformation where recognized personally identifiable information (PII) elements are replaced with cryptographically-hashed pseudonymous placeholders (e.g., [EMAIL#A7B8C9D2]) before any further analysis. This obfuscates original sensitive values while maintaining analytical utility through deduplication and in-conversation linkability.
- Automated Analysis Stage: Pseudonymized conversations are processed using open-weight Large Language Models (LLMs) deployed locally on secure, isolated infrastructure to identify privacy categories, assess risk levels, and analyze disclosure patterns. No conversation content is transmitted to external APIs or third-party service providers.
- Manual Validation Stage: A stratified random sample of 200 conversations is manually reviewed by three independent privacy experts to validate the automated framework's reliability and accuracy. Annotators assess privacy issues, identify categories, and tag PII types under confidentiality.
- Statistical Analysis and Reporting Stage: Aggregated statistics and patterns are derived from the analyzed dataset. Only aggregate findings are reported; no individual conversation content (raw or redacted) is published or distributed.
- Data Retention and Deletion: All conversation trace datasets collected for this study will be irrevocably deleted upon study publication completion.

Data Controller

The Data Controller is:

Fondazione Bruno Kessler, with registered office in Trento, via Santa Croce, 77 (Italy).

Pursuant to art. 37 of the Regulation, the Data Controller has designated a Data Protection Officer (DPO) who may be reached via the following channels: privacy@fbk.eu, +39.0461.314.370.

The purpose

Your personal data is processed and for the following research purposes:

1) Scientific Research and Knowledge Advancement: To advance scientific understanding of privacy risks in AI-assisted communication systems, characterize disclosure patterns across different chatbot platforms, and contribute to the development of safer conversational AI technologies;

2) Privacy Risk Assessment Framework Development: To develop, validate, and refine automated privacy detection methodologies using LLMs that can identify personally identifiable information (PII), classify privacy categories according to established taxonomies, assess risk severity levels, and map disclosures to LINDDUN privacy threat types;

3) Empirical Pattern Analysis: To systematically analyze privacy disclosure patterns in AI chatbot conversations, including temporal progression of disclosures, correlation between conversation characteristics and disclosure severity, and identification of high-risk contexts where users may inadvertently expose sensitive information;

4) Framework Validation and Reliability Assessment: To conduct manual expert validation studies comparing automated detection against human annotator judgments, measure inter-annotator reliability, calculate detection performance metrics, and ensure methodological rigor through statistical analysis;

5) Evidence-Based Recommendation Generation: To generate actionable, evidence-based recommendations for multiple stakeholders including: (a) AI platform providers to implement proactive privacy safeguards, (b) users to increase awareness of disclosure risks, and (c) policymakers to inform privacy regulation in conversational AI contexts;

6) Academic Dissemination: To publish aggregated research findings, statistical analyses, and methodological frameworks in peer-reviewed academic venues, contributing to the broader scientific community's understanding of privacy risks in AI-assisted communication while ensuring no individual conversation content is disclosed;

7) Reproducibility and Methodological Transparency: To document and validate the analysis pipeline, enabling reproducible research practices and allowing independent verification of findings through publication of analysis code, synthetic test cases, and methodological documentation (excluding actual conversation data).

What data will be processed?

We may process the following personal data:

Source of Personal Data

Personal data has not been collected directly from individuals. All data originates from publicly accessible conversation traces discovered via search engine queries on AI chatbot platforms.

Categories of Personal Data

The conversations analyzed may contain the following categories of personal data, organized according to our privacy taxonomy:

- Identity/Profile data: names, job titles, employers, organizational affiliations, demographic attributes (age, gender, nationality, ethnicity, sexual orientation), family relationships, information about minors
- Contact information: email addresses, phone numbers, physical addresses, social media handles and usernames
- Location data: geographic addresses, travel history and movement patterns
- Health data (special category): medical conditions and diagnoses, mental health information, medication details, medical test results, health records
- Financial data: cryptocurrency wallet addresses, bank account information, tax-related data
- Identification credentials: government-issued identifiers, account IDs, usernames, biometric identifiers
- Authentication credentials: API keys, access tokens, passwords, authentication

secrets
- Network data: IP addresses (public and private), hostnames, network identifiers, private URLs
- System data: local file paths, directory structures, configuration data
- Legal information: case numbers, legal document references
- Safety-related data: information indicating potential harm, abuse, or trafficking risks

Special Categories of Personal Data (GDPR Article 9):

The dataset may contain health/medical information, biometric data, data concerning sexual orientation, racial or ethnic origin, and data concerning minors.

In accordance with the data minimization principle, only the personal data that are deemed necessary for the project's objectives will be processed (see section "How will the data be processed").

The legal basis

With respect to the processing of personal data, the applicable legal ground for such processing activities is legitimate interest. The legal ground for processing sensitive data is art 9, para 2, lett. j in combination with art. 89 GDPR.

How will the data be processed?

The Controller will aim to minimize the amount of personal data collected through the different activities.

Your personal data shall be processed:

Through automated and manual means:

- Automated collection of conversation URLs via search engine queries
- Automated pseudonymization replacing all identified PII with cryptographic hash placeholders
- Automated privacy analysis using locally-deployed open-weight Large Language Models
- Manual expert validation by three independent privacy researchers on a stratified sample
- Statistical analysis and aggregation of findings

By authorized individuals only:

- Processing performed exclusively by named research team members with appropriate training in data protection and research ethics
- Manual validation conducted by three privacy experts bound by confidentiality agreements
- No distribution of raw or pseudonymized conversation data beyond the core research team

Using proper security measures:

- All processing conducted on secure, isolated infrastructure with no internet connectivity for sensitive operations
- No transmission of conversation content to external APIs or third-party service providers
- Local deployment of all LLM analysis models (no cloud-based processing)
- Access controls and audit logging for all data handling activities

In pseudonymized form:

- Mandatory cryptographic pseudonymization applied before any LLM analysis
- Original PII values replaced with hashed placeholders (e.g., [EMAIL#A7B8C9D2])
- Pseudonymization maintains analytical utility while preventing direct identification

Data Processing State:

All personally identifiable information undergoes cryptographic pseudonymization prior to automated analysis. Original sensitive values are replaced with hashed placeholders (e.g., [EMAIL#A7B8C9D2]) that maintain analytical utility while preventing direct identification. Only pseudonymized data is processed through LLM analysis pipelines.

With minimal human exposure:

- Only 200 conversations (out of the full dataset) manually reviewed for validation purposes
- No manual reading or processing of the remaining conversations
- Automated pipelines process data without human inspection of content

Ensuring data subject dignity:

- Processing conducted solely for scientific research purposes, not for profiling or discriminatory purposes
- Aggregated findings only—no individual conversation content published or disclosed
- Analysis focuses on patterns and statistical trends, not individual cases
- Special sensitivity applied to conversations involving minors, health conditions, or vulnerable populations

With time-limited retention:

- All conversation data will be irrevocably deleted upon study publication
- No long-term storage or archival of raw conversation traces
- Only aggregated statistical results and analysis code retained for reproducibility
- No automated decision-making process, nor any profiling activity is taking place.

Where will data be processed?

The activity of processing personal data takes place on the territory of the **European Union.** Should the activity include personal data processing outside the European Union, in the absence of an adequacy decision from the European Commission, we will undertake additional measures in order to guarantee a level of protection equivalent to the one offered in the European Union. We will respect the provisions set out by the applicable legislation on personal data transfer towards third countries (chapter V of the GDPR), such as Standard Contractual Clauses provided by the European Commission.

As FBK is using Google and Microsoft, and data transfer outside the European Union is not excluded, we will make sure that such a data transfer will take place within the limits and the conditions set forth in chapter V of the GDPR.

How long will the personal data be stored?

The storage duration of the data will be the duration of the project (July 2026), unless a longer retention period is required by law or for the establishment, exercise or defense of legal claims.

Will the personal data be shared?

No. Personal data (raw or pseudonymized conversation content) will not be shared with any third parties, external organizations, or publicly disclosed.

Your rights

You have certain rights regarding your personal information. Read more about them below.

- **Right to be informed** – this information sheet is designed to inform you about the use of your personal data. You also have the right to know whether automatic decision-making (e.g. by an algorithm) is taking place.
- **Right of Access** – you have the right to have a copy of the information that is being processed and to make a Subject Access Request (via the project partner organisation's

DPO or relevant expert, contact details below).

- **Right to Rectification** – you have the right to have inaccurate personal data rectified. You may also be able to have incomplete personal data completed.
- **Right to Restrict Processing** – you have the right to request the restriction or suppression of your personal data. This means you can limit the way the project uses your personal data rather than having it erased.
- **Right to Erasure** – you have the right to have your personal data erased. However, the project will not retain personal data unless a valid legal basis for doing so exists**.**
- **Right to Data Portability** – you have the right to obtain and use your personal data for your own purposes, where the legal basis for processing is consent or the performance of a contract.
- **Right to Object** – you have the right to object to the processing of your personal data at any time.

To exercise the rights mentioned above, please reach out to the following contacts:

Contact details

For questions about this project and/or processing activities, please contact:	**For exercising your data subject rights, please contact:**
Project Coordinator address: Via Sommarive, 18, 38123 Povo TN, Center for Cybersecurity, Security and Trust Unit email: ranise@fbk.eu	**DPO/Privacy Unit** address: Via Sommarive, 18, 38123 Povo TN email:privacy@fbk.eu

Complaint?

If you wish to complain to your national Data Protection Supervisory Authority, these are listed in the following link: https://edpb.europa.eu/about-edpb/about-edpb/members_en

Updates of this Privacy Policy

The data controller reserves the right to make, if necessary, the appropriate changes to this Privacy Policy – currently updated on 11/02/2026 giving the widest visibility to the Data Subjects.